LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING

Barracuda ESG CVE-2026-116606 and CVE-2026-111560 Exploited Chain Daily Priority

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-11-13
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | Barracuda ESG CVE-2026-116606 and CVE-2026-111560 Exploited Chain Daily Priority - CVE / Vulnerability Threat Intelligence Report

Published: 2026-11-13 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Affected Products and Exposure
7. Aviation and Aerospace Sector Impact
8. Mitigation and Workarounds
9. Detection Engineering
10. Threat Hunting
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

Barracuda ESG CVE-2026-116606 and CVE-2026-111560 Exploited Chain Daily Priority

1. Executive Summary

CISA added CVE-2026-116606 and CVE-2026-111560 to the Known Exploited Vulnerabilities (KEV) Catalog on 2026-11-10. The vendor advisory describes an authentication bypass in Barracuda Email Security Gateway (ESG) and a command-injection flaw shared by ESG and several Barracuda appliance families. CISA states the flaws can be chained: the bypass can permit restoration of a crafted compatible backup and unauthorized configuration modification, while the command-injection issue can execute commands as root when a crafted timezone value is processed.

Treat exposed or remotely administered ESG appliances as an urgent containment, patching, and historical-access-review priority. KEV inclusion is evidence of exploitation in the wild; it does not prove compromise of a particular organization. This report does not claim attribution, exploit availability, or aviation-sector victimization.

2. Vulnerability Metadata

Field	CVE-2026-116606	CVE-2026-111560
Weakness	Authentication bypass / alternate path	Improper neutralization of shell metacharacters
Product scope	Barracuda Email Security Gateway	ESG, ADC, BMA, WCC, WAF, and WSG
Preconditions	Administrative UI reachability; no authentication stated by vendor	Administrative access; crafted timezone later processed
Impact	Unauthorized global configuration modification	Root command execution
Exploitation status	CISA KEV-listed 2026-11-10	CISA KEV-listed 2026-11-10
Remediation	Upgrade to vendor-fixed firmware	Upgrade to vendor-fixed firmware

3. Source Review & Confidence

Source	Contribution	Confidence
Barracuda security advisory	Primary scope, CVSS, authentication and remediation statements	High
CISA KEV Catalog	Active-exploitation prioritization and federal remediation due date	High
NVD CVE records	Canonical CVE descriptions and reference chain	High
Mandiant disclosure MNDT-2026-0041/0042	Technical disclosure references listed by NVD	High
SecurityWeek	Supporting public reporting on the pair and stated severity	Medium

The vulnerability and remediation claims are grounded in primary/authoritative records. Public exploitation is supported by KEV inclusion. No reviewed source proves a specific intrusion chain in a local environment.

4. Vulnerability Details

CVE-2026-116606 affects ESG versions earlier than 9.4.0.030 according to the NVD description. It permits an unauthenticated remote attacker who can reach the administrative interface to invoke a configuration-import function and restore a crafted compatible backup. CVE-2026-111560 affects common Barracuda code across the listed appliance families and permits an authenticated administrator to inject OS commands through a timezone setting that is later processed. The vendor advisory describes CVE-2026-116606 as a pre-authentication authorization bypass and CVE-2026-111560 as command injection.

5. Attack Scenarios

Scenario	Preconditions	Defender focus
External administrative-interface exposure	ESG administrative UI reachable from untrusted networks	Remove exposure; preserve edge logs before change
Chained configuration-to-root path	Compatible crafted backup and a subsequent privileged configuration path	Review imports, configuration changes, and admin events
Remote-support pivot	Third-party or VPN access reaches appliance administration	Correlate VPN, jump-host, and ESG administrative activity
Lateral appliance management	Attacker already has management-network access	Enforce segmentation and named-admin access paths

6. Affected Products and Exposure

Asset condition	Risk	Immediate action
ESG below vendor-fixed firmware with reachable admin UI	Critical	Isolate administration, patch under change control, investigate access
Other affected Barracuda appliances below fixed firmware	High	Inventory timezone changes and upgrade
ESG patched but historically exposed	High	Retain/review historical web, admin, and configuration logs
Appliance confirmed out of scope	Verify	Record model, firmware, and evidence of non-applicability

7. Aviation and Aerospace Sector Impact

Segment	Operational relevance	Likely exposure path	Defender action
Airline and airport email security	ESG can protect operational, crew, vendor, and passenger-support mail	Internet-facing admin portals, outsourced email operations	Limit admin access to managed jump hosts and verify firmware
Aerospace manufacturing and MRO	Email gateways may bridge supplier, engineering, and maintenance workflows	Supplier remote support and shared management networks	Validate third-party accounts and preserve appliance configuration evidence
Defense and space ground organizations	Gateway compromise can enable phishing staging or credential targeting	Partner-connected administration and identity federation	Hunt for unauthorized imports and review privileged sessions

Sector relevance reflects common use of email-security infrastructure; it is not a claim that a named aviation or aerospace organization is affected.

8. Mitigation and Workarounds

1. Identify all ESG, ADC, BMA, WCC, WAF, and WSG appliances, their firmware, owners, and administrative interfaces.
2. Apply Barracuda's current firmware remediation under approved change control; verify the installed version after reboot/maintenance.
3. Remove public administrative access. Restrict appliance management to dedicated jump hosts and allowlisted administrators.
4. Preserve web, VPN, authentication, audit, backup/import, timezone/configuration, and command-execution artifacts before remediation when feasible.
5. Rotate appliance-administration credentials and review integration/service accounts where unauthorized access is plausible.

9. Detection Engineering

Signal	Telemetry	Analytic objective
Requests to ESG administration from unapproved sources	Firewall, reverse proxy, appliance web logs	Identify exposed or probed management paths
Configuration import/restore or timezone change	Barracuda audit/configuration logs	Identify chain-relevant state changes
New privileged session after an import	Appliance/VPN/jump-host logs	Prioritize suspected post-exploitation activity

```
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemotePort in (443, 8443)
| where RemoteIPType == "Public"
| project Timestamp, DeviceName, RemoteIP, RemoteUrl, InitiatingProcessFileName
| order by Timestamp desc
```

10. Threat Hunting

Hypothesis: an ESG management interface was accessed from an unapproved network and was followed by backup/import or configuration activity.

```
index=network earliest=-30d (dest_port=443 OR dest_port=8443) action=allowed
| stats values(src_ip) as sources count by dest_ip, dest_port
| sort - count
```

Correlate hits with the authoritative ESG inventory, approved maintenance windows, VPN records, appliance audit entries, and backup/import events. Do not treat a network hit alone as exploitation evidence.

11. MITRE ATT&CK Mapping

Technique	Name	Rationale
T1190	Exploit Public-Facing Application	Applies where an exposed management interface is targeted; not incident proof
T1059	Command and Scripting Interpreter	Analytic mapping for the command-injection effect of CVE-2026-111560

12. Validation / Lab Testing

No exploit was run. Validation consisted of reviewing Barracuda, CISA KEV, NVD, and cited disclosure records, then constructing inventory, exposure, detection, and hunt guidance. Test upgrades and management-plane restrictions only in an authorized maintenance environment.

13. Recommended Actions Summary

Priority	Owner	Action
Critical	Messaging/security owner	Inventory and patch all in-scope Barracuda appliances
Critical	Network team	Remove untrusted administrative-interface reachability
High	SOC/IR	Review admin, import/restore, configuration, and VPN history
High	Aviation/aerospace supplier-management teams	Confirm service-provider ownership and privileged-access controls

14. References

- https://trust.barracuda.com/security/pre-authentication-authorization-bypass-command-injection
- https://www.cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2026-116606
- https://nvd.nist.gov/vuln/detail/CVE-2026-116606
- https://nvd.nist.gov/vuln/detail/CVE-2026-111560
- https://github.com/mandiant/Vulnerability-Disclosures/blob/master/2026/MNDT-2026-0041.md
- https://github.com/mandiant/Vulnerability-Disclosures/blob/master/2026/MNDT-2026-0042.md
- https://www.securityweek.com/barracuda-email-security-gateway-authentication-bypass-opens-path-to-root/